

Vulnerability Assessment Report

20th March 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2026 to August 2026. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

The company is doing e-commerce and storing the information about potential clients in the remote database. It means, that this database is crucial as for the organization, as for it's clients. It determines how much money will the company earn and will the data of the clients remain private and safe from unauthorized access to it. Malicious actors may conduct an attack, exploit the data and then, for example, transfer people's money, hack their accounts and sell their PII (which will lead to fees and other restrictive measures established by authorities). Due to that company may lose money, reputation and even stop it's existing.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Craft counterfeit certificates	2	3	6
Competitor	Alter/Delete critical information	2	3	6
Supplier	Obtain sensitive information via exfiltration	2	2	4

Approach

All of the threat source mentioned potentially want to take advantage of the company's vulnerabilities and your failure would be a huge "pleasure" for them. Hacker can sell the information or transfer client's money to his own bank account; competitor can destroy your reputation by disrupting your day-to-day business operations and then lure your customer base; finally, supplier may want no to be a member of "third party" and contact clients directly instead of working with you.

Likelihood scoring: Because the database is open, but the connections are secured, it's easy to access and possible enough to establish connection with the clients, if you have an intention and some technical skills to do that. Hacker may do it by his own, but your competitor and supplier need to hire someone to deploy their "operation".

Severity scoring: Hacker can steal PII of your clients, also their money. If this happened, company will lose their reputation and it even can be closed, if the affected clients decide to report about that to the authorities. If the competitor's threat event is deployed, company has different following paths: 1. Clients will just leave your company because of the lack of compliance and low client-experience, then go buying things from your competitor 2. They will report the authorities about the accidents and if there are too many of them, company will be closed If the supplier decide to take advantage of the company, it may lose it's clients and, hence, income, but it can be restored by addressing the problem, finding new supplier and bringing back the customer base.

Remediation Strategy

Implementation of authentication, authorization, and auditing controls to ensure that access to the database server is restricted to verified and approved users. This involves enforcing strong password policies, applying role-based access control (RBAC), and enabling multi-factor authentication to limit privileges according to user responsibilities. In line with the principle of separation of duties, access rights are distributed so that no single user has excessive control over critical operations. Data in transit is protected through encryption using TLS rather than SSL. Additionally, IP allow-listing is applied to restrict connections exclusively to corporate office networks, thereby preventing unauthorized external access.